



GRUPO 13



Miembros del Grupo:

Mario Martín Feliz (Portavoz)

Mario Bote Sánchez

Oscar Cardeña Gutiérrez

Formulario de autorización de Pentesting

Índice contenido

- **Formulario de autorización de Pentesting.**
- **Tipos de pruebas (Pentesting)**
 - Restricciones y conformidades.
- **Acuerdo de confidencialidad.**
 - Obligaciones Grupo13 Analytics.
 - Exclusiones.
 - Derechos de propiedad.
 - Vigencia.
 - Legislación aplicable.

Formulario de autorización de Pentesting.

Cliente:

Nombre:

Puesto:

Fecha:

Autoriza a Grupo13 Analytics para llevar a cabo las actividades de verificación de seguridad de la aplicación(es) y sistema (s) que se describe(n) a continuación, según las siguientes condiciones:

- **Ámbito de las pruebas (Activos autorizados):**
 - <https://www.xxxxx.xxx>
- **Condiciones:**
 - Las pruebas serán externas e internas y se realizarán desde fuera y dentro de la red del cliente utilizando Internet y para acceder a los activos incluidos en el alcance.
 - Se realizarán un único TEST de penetración:
 - Caja negra.
- **Planificación temporal:**
 - Fechas: Del xx de xx al xx de xx de xxxx.
 - Horario: **De xx:xx a xx:xx horas.**
- **Teléfonos de soporte en caso de caída de servicio:**
 - **Por parte del equipo de producto o cliente:**
 - Nombre:
 - Teléfono:
 - Email:
 - **Auditor(GRUPO13 ANALYTICS):**
 - Nombre:
 - Teléfono:
 - Email: xxxx@grupo13analytics.com

Tipos de pruebas (Pentesting.)

El servicio de test de intrusión nos permite testear la fortaleza de la infraestructura IT para medir su nivel de seguridad técnico y si cumple los niveles requeridos por la política organizativa. Estos test son realizados por expertos en seguridad sobre todos los servicios expuestos a internet y aquellos que puedan accederse remotamente.

Se pueden realizar dos tipos distintos de Test de Intrusión, Externo o Interno dependiendo desde dónde se lancen los ataques.

- **El Test de Intrusión Externo:** se realiza desde internet sobre la infraestructura del cliente, más concretamente, sobre aquellos dispositivos de la organización que están expuestos a internet, por ejemplo, Router, firewall, servidor web, servidor de correo, DNS, etc.
- **El Test de Intrusión Interno:** se realiza desde dentro de la red del cliente desde donde pueden localizarse más problemas de seguridad que desde fuera.
- **Propósito del *pentest*:** Comprobar el estado de las vulnerabilidades que presenta la aplicación web objeto de este.

Se pueden realizar dos tipos distintos de Test de Intrusión, Externo o Interno dependiendo desde dónde se lancen los ataques.

- **Test de Intrusión de Caja Negra:** este es un tipo de test de intrusión externo, sin información o solo con muy poca información del objetivo (solo lo que debe ser auditado). Por ejemplo, dada una web o portal publicado, intentar atacarlo desde una red externa sólo a partir de información básica disponible, desconociendo información relativa a arquitectura, usuarios, etc.
- **Test de Intrusión de Caja Gris:** este tipo de test puede ser interno o externo, poseyendo solo información limitada sobre el objetivo como, por ejemplo, credenciales de autenticación básicas.
- **Test de Intrusión de Caja Blanca:** este tipo de test es interno, accediendo a la red desde un punto de acceso y teniendo el diagrama de red, las plataformas, los servicios principales, y varios perfiles con distintas credenciales y privilegios, etc.

Dada la naturaleza de los trabajos a realizar cabe la posibilidad de que, de forma no intencionada, se produjese algún efecto colateral indeseado. Si así fuese, el Auditor de GRUPO13 ANALYTICS lo notificaría inmediatamente al Teléfono de soporte correspondiente o se pondría a disposición del cliente para aportar la información requerida sobre las acciones realizadas.

Restricciones y conformidades:

Las siguientes restricciones se aplicarán a esta autorización:

- Esta autorización estará vigente desde el xx de xx de xxxx hasta el xx de xx de xxxx, ambos inclusive.

De conformidad con la concesión de esta autorización, el Cliente declara que:

- El cliente es dueño de los sistemas donde se realiza la auditoria de vulnerabilidades y el suscrito tiene la autoridad adecuada para poder llevar a cabo las actividades de verificación de seguridad de aplicaciones.
- El cliente ha creado una copia de seguridad completa de todos los sistemas dentro del ámbito de las pruebas de vulnerabilidades, y se ha comprobado que el procedimiento de copia de seguridad permitirá al cliente restaurar los sistemas a su estado pre-test.
- El servicio implica necesariamente el uso de herramientas y técnicas diseñadas para detectar las vulnerabilidades de seguridad, y que es imposible identificar y eliminar todos los riesgos que implica el uso de estas herramientas y técnicas.
- El cliente se compromete a no modificar el sistema o aplicativo durante la ejecución del pentesting. Si esto sucediera se entenderá como un cambio de alcance, de tal modo que el pentesting se dará por finalizado y se entregará el informe al cliente con los resultados obtenidos hasta ese momento, con lo que el Auditor cumplirá totalmente con el alcance inicialmente acordado. Si el cliente desea realizar un pentesting al sistema o aplicativo que ha modificado deberá volver a negociarlo con GRUPO13 ANALYTICS considerándose en todo caso como el encargo de un nuevo trabajo.

Cualquier cambio a las limitaciones y condiciones descritas deberá realizarse por escrito y ser aceptado por ambas partes.

ACUERDO DE CONFIDENCIALIDAD.

Será considerada como “Información Confidencial” toda aquella información, ya sea técnica, financiera, comercial o de cualquier otro carácter, suministrada y divulgada por la empresa cliente a GRUPO13 ANALYTICS en relación con el alcance del contrato, mediante cualquier tipo de soporte, tangible o intangible, actualmente conocido o que posibilite el estado de la técnica en el futuro (papel, informático, etc.) o de forma verbal.

Obligaciones Grupo13 Analytics:

Nada más recibir la Información Confidencial, GRUPO13 ANALYTICS la mantendrá en estricta confidencialidad, la utilizará solamente en relación con las pruebas del alcance, no la revelará a una tercera parte sin el previo consentimiento escrito de la empresa cliente y sólo podrá revelar dicha Información Confidencial a los empleados de su compañía o que tengan necesidad expresa de conocerla en relación con las pruebas contratadas.

GRUPO13 ANALYTICS no podrá copiar ni reproducir la Información Confidencial suministrada por la otra Parte en formato o soporte alguno, excepto si ello fuera preciso con arreglo a lo previsto en el párrafo anterior. Toda copia o reproducción que se haga deberá contener el mismo sello, marca o leyenda que su original.

Exclusiones:

Las Partes acuerdan que las obligaciones contenidas en este Acuerdo no se aplicarán respecto de aquella información que ...:

- ... esté, sea o llegue a ser de público conocimiento sin mediar acto proveniente de GRUPO13 ANALYTICS en contravención de los términos de este Compromiso;
- ... deba ser difundida por imperativo de una disposición legal, contractual o judicial;
- ... sea explícitamente identificada, de conformidad con este Compromiso, como Información No Confidencial;
- ... cuya comunicación o uso sin restricciones haya sido aprobada por la empresa cliente;
- ... sea independientemente generada por GRUPO13 ANALYTICS sin hacer uso de la Información Confidencial;
- ... haya sido requerida a la Parte receptora mediante una resolución firme por Autoridades Administrativas o Judiciales competentes. En este caso deberá notificarse inmediatamente esta circunstancia a la empresa cliente sobre el requerimiento recibido, siempre que no exista obligación de guardar secreto sobre el mismo por mandato legal, administrativo o judicial. Asimismo, GRUPO13 ANALYTICS sólo revelará aquella parte de la información que sea requerida.

Derechos de propiedad:

Este Acuerdo no supone la concesión, expresa o implícita, de derecho alguno sobre la Información Confidencial que la empresa cliente suministre, salvo el que en cada caso sea otorgado expresamente en relación con el Alcance del presente contrato.

En consecuencia, el suministro de dicha Información no podrá entenderse, en ningún caso, como concesión de patente, licencia o cualquier otro derecho de propiedad intelectual y/o industrial alguno, considerándose que aquella permanecerá en todo momento en el ámbito de propiedad de la empresa cliente o del tercero a quien pertenezca.

Vigencia:

Las obligaciones previstas en la cláusula 2 permanecerán en vigor hasta que hayan transcurrido 3 años contados a partir de la fecha de entrega del informe de resultados del presente contrato.

Legislación aplicable:

Este compromiso se interpretará de conformidad con las leyes españolas, vigentes al momento de su firma.

Si alguna de las Partes es objeto de una fusión u otro tipo de reorganización societaria, se acuerda que este Compromiso será vinculante para el que le suceda de acuerdo con la ley aplicable.

POR EL CLIENTE:		Auditor (Grupo13 Analytics):	
Fdo.:		Fdo.:	
Fecha: xx de xx de xxxx		Fecha: xx de xx de xxxx	